



Attacking Web Applications with Ffuf | Skills Assessment - Web Fuzzing Write-up

HackTheBox

Written by: Alexander Sapo

Scenario:

You are given an online academy's IP address but have no further information about their website. As the first step of conducting a Penetration Test, you are expected to locate all pages and domains linked to their IP to enumerate the IP and domains properly.

Finally, you should do some fuzzing on pages you identify to see if any of them has any parameters that can be interacted with. If you do find active parameters, see if you can retrieve any data from them.

Questions

Question 1

Run a sub-domain/vhost fuzzing scan on `*.academy.htb` for the IP shown above. What are all the sub-domains you can identify? (Only write the sub-domain name)

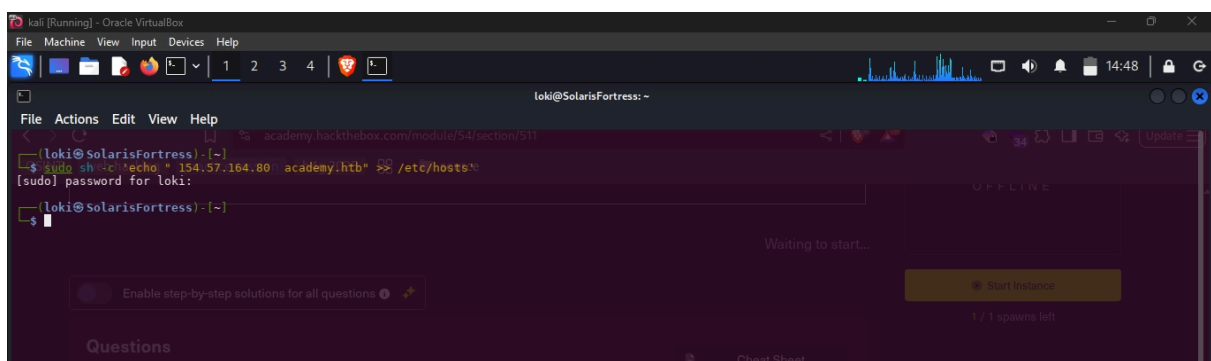
flag:

test archive faculty

Process

Since the task specifies **VHOST fuzzing**, first add the target domain to

`/etc/hosts`:



```
sudo sh -c 'echo "SERVER academy.htb" >> /etc/hosts'
```

Note: This step must be repeated whenever the target machine resets or expires.

Next, perform an initial fuzzing scan to identify the **common error response size**:

```
loki@SolarisFortress: ~  
File Actions Edit View Help  
 academy.htb:30376  
[loki@SolarisFortress:~]  
$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt:FUZZ -u http://academy.htb:30376/ -H 'Host: FUZZ.academy.htb'  
  
v2.1.0-dev  
  
:: Method : GET  
:: URL : http://academy.htb:30376/  
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt  
:: Header : Host: FUZZ.academy.htb  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
  
secure [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 422ms]  
gp [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 425ms]  
demo [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 425ms]  
autodiscover [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 423ms]  
mx [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 426ms]  
ns3 [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 427ms]  
www [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 551ms]  
dns1 [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 300ms]  
www1 [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 299ms]  
static [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 299ms]  
img [Status: 200, Size: 985, Words: 423, Lines: 55, Duration: 292ms]
```

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt:FUZZ -u http://academy.htb:30376/ -H 'Host: FUZZ.academy.htb'
```

Common error response size identified: **985**

This value will be used as a filter.

Run the fuzzing scan again with the response size filter:

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt:FUZZ -u http://academy.htb:30376/ -H 'Host: FUZZ.academy.htb' -fs 985
```

Results:

```
loki@SolarisFortress: ~  
File Actions Edit View Help  
 academy.htb:30376  
[loki@SolarisFortress:~]  
$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt:FUZZ -u http://academy.htb:30376/ -H 'Host: FUZZ.academy.htb' -fs 985  
  
v2.1.0-dev  
  
:: Method : GET  
:: URL : http://academy.htb:30376/  
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt  
:: Header : Host: FUZZ.academy.htb  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter : Response size: 985  
  
test [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 226ms]  
archive [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 412ms]  
faculty [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 370ms]  
[WARN] Caught keyboard interrupt (ctrl-c)
```

```
test      [Status: 200]
archive   [Status: 200]
faculty   [Status: 200]
```

Before proceeding, add all discovered subdomains to `/etc/hosts` :

```
loki@SolarisFortress: ~
File Actions Edit View Help
< Not secure academy.htb:30376
[loki@SolarisFortress] (~)
$ sudo sh -c 'echo " 154.57.164.80 test.academy.htb" >> /etc/hosts'
[sudo] password for loki:
[loki@SolarisFortress] (~)
$ sudo sh -c 'echo " 154.57.164.80 archive.academy.htb" >> /etc/hosts'
[loki@SolarisFortress] (~)
$ sudo sh -c 'echo " 154.57.164.80 faculty.academy.htb" >> /etc/hosts'
[loki@SolarisFortress] (~)
$
```

`<subdomain>.academy.htb`

Question 2

Before you run your page fuzzing scan, you should first run an extension fuzzing scan. What are the different extensions accepted by the domains?

flag: php php7 phps

Process

Run an extension fuzzing scan against each discovered domain:

```
loki@SolarisFortress: ~
File Actions Edit View Help
$ ffuf -w /usr/share/seclists/Discovery/Web-Content/raft-large-extensions.txt -u http://test.academy.htb:30376/indexFUZZ -H 'Host: test.academy.htb'
OSINT [v2.1.0-dev]
v2.1.0-dev

:: Method      : GET
:: URL         : http://test.academy.htb:30376/indexFUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/raft-large-extensions.txt
:: Header      : Host: test.academy.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout      : 10
:: Threads      : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500

.php      [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 1160ms]
.phpps    [Status: 403, Size: 281, Words: 20, Lines: 10, Duration: 315ms]
.php      [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 227ms]
:: Progress: [2450/2450] :: Job [1/1] :: 115 req/sec :: Duration: [0:00:21] :: Errors: 0 ::
```

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/web-extensions-big.txt:FUZZ -u http://test.academy.htb:PORT/indexFUZZ -H 'Host: test.academy.htb'
```

Purpose: identify common file extensions supported by the target web application.

Since testing locally, the VHOST header must still be specified.

Repeat the same process for:

```
test.academy.htb
archive.academy.htb
faculty.academy.htb
```

Apply response size filters identified per domain fuzzed:

```
test      -fs 281
archive   -fs 284
faculty   -fs 284
```

Common accepted extensions identified:

```
php
phps
php7
```

These extensions will be used for subsequent page fuzzing.

Question 3

One of the pages you will identify should say "You don't have access!". What is the full page URL?

flag:

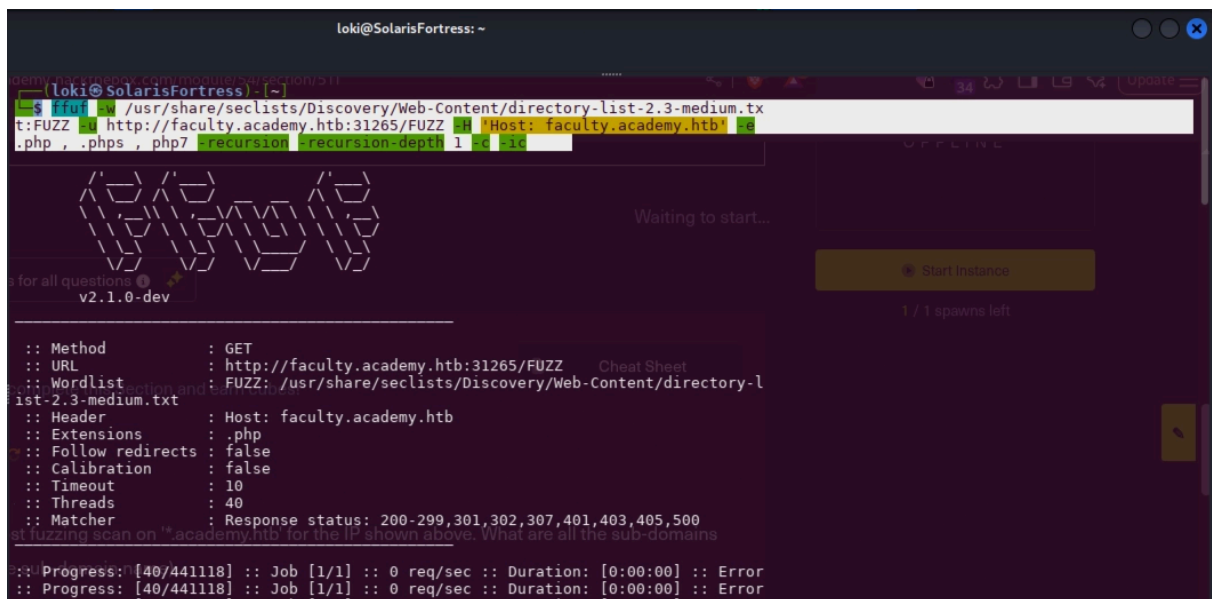
<http://faculty.academy.htb:PORT/courses/linux-security.php7>

Process

Fuzz each domain for directories using recursion to discover subdirectories.

After multiple fuzzing attempts, the target page was found under the **faculty** domain.

Initial directory fuzzing:



```
loki@SolarisFortress: ~  
$ ffuf -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt  
-t:FUZZ -u http://faculty.academy.htb:31265/FUZZ -H 'Host: faculty.academy.htb' -e  
.php, .phps, .php7 -recursion -recursion-depth 1 -c -ic  
  
Waiting to start...  
  
Start Instance  
1 / 1 spawns left  
  
:: Method : GET  
:: URL : http://faculty.academy.htb:31265/FUZZ  
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt  
:: Header : Host: faculty.academy.htb  
:: Extensions : .php  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
st fuzzing scan on "faculty.academy.htb" for the IP shown above. What are all the sub-domains  
:: Progress: [40/441118] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error  
:: Progress: [40/441118] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
```

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/directory  
-list-2.3-medium.txt:FUZZ -u http://faculty.academy.htb:POR  
T/FUZZ -H 'Host: faculty.academy.htb' -e .php,.phps,.php7 -  
recursion -recursion-depth 1 -c -ic
```

Discovered directory:

```
loli@SolarisFortress: ~  
:: Progress: [359/441118] :: Job [1/1] :: 105 req/sec :: Duration: [0:00:04] :: Er  
# on at least 2 different hosts.php [Status: 200, Size: 0, Words: 1, Lines: 1, Dur  
ation: 4280ms]  
:: Progress: [361/441118] :: Job [1/1] :: 107 req/sec :: Duration: [0:00:04] :: Er  
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 0,  
Words: 1, Lines: 1, Duration: 4306ms]  
:: Progress: [362/441118] :: Job [1/1] :: 108 req/sec :: Duration: [0:00:04] :: Er  
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php [Status: 200,  
Size: 0, Words: 1, Lines: 1, Duration: 4314ms]  
:: Progress: [363/441118] :: Job [1/1] :: 106 req/sec :: Duration: [0:00:04] :: Er  
:: Progress: [369/441118] :: Job [1/1] :: 109 req/sec :: Duration: [0:00:04] :: Er  
:: Progress: [385/441118] :: Job [1/1] :: 115 req/sec :: Duration: [0:00:04] :: Er  
:: Progress: [409/441118] :: Job [1/1] :: 130 req/sec :: Duration: [0:00:04] :: Er  
:: Progress: [424/441118] :: Job [1/1] :: 134 req/sec :: Duration: [0:00:04] :: Er  
:: Progress: [448/441118] :: Job [1/1] :: 138 req/sec :: Duration: [0:00:05] :: Er  
:: Progress: [463/441118] :: Job [1/1] :: 144 req/sec :: Duration: [0:00:05] :: Er  
:: Progress: [477/441118] :: Job [1/1] :: 143 req/sec :: Duration: [0:00:05] :: Er  
:: Progress: [516/441118] :: Job [1/1] :: 160 req/sec :: Duration: [0:00:05] :: Er  
:: Progress: [517/441118] :: Job [1/1] :: 158 req/sec :: Duration: [0:00:05] :: Er  
:: Progress: [557/441118] :: Job [1/1] :: 172 req/sec :: Duration: [0:00:05] :: Er  
:: Progress: [570/441118] :: Job [1/1] :: 170 req/sec :: Duration: [0:00:05] :: Er  
:: Progress: [594/441118] :: Job [1/1] :: 172 req/sec :: Duration: [0:00:05] :: Er  
:: Progress: [620/441118] :: Job [1/1] :: 165 req/sec :: Duration: [0:00:06] :: Er  
:: Progress: [631/441118] :: Job [1/1] :: 177 req/sec :: Duration: [0:00:06] :: Er  
:: Progress: [670/441118] :: Job [1/1] :: 176 req/sec :: Duration: [0:00:06] :: Er  
:: Progress: [673/441118] :: Job [1/1] :: 160 req/sec :: Duration: [0:00:06] :: Er  
:: Progress: [709/441118] :: Job [1/1] :: 172 req/sec :: Duration: [0:00:06] :: Er  
:: Progress: [723/441118] :: Job [1/1] :: 176 req/sec :: Duration: [0:00:06] :: Er  
:: Progress: [747/441118] :: Job [1/1] :: 173 req/sec :: Duration: [0:00:06] :: Er  
:: Progress: [775/441118] :: Job [1/1] :: 174 req/sec :: Duration: [0:00:06] :: Er  
:: Progress: [784/441118] :: Job [1/1] :: 168 req/sec :: Duration: [0:00:07] :: Er  
:: Progress: [818/441118] :: Job [1/1] :: 175 req/sec :: Duration: [0:00:07] :: Er  
:: Progress: [821/441118] :: Job [1/1] :: 165 req/sec :: Duration: [0:00:07] :: Er  
:: Progress: [856/441118] :: Job [1/1] :: 173 req/sec :: Duration: [0:00:07] :: Er  
courses [Status: 301, Size: 328, Words: 20, Lines: 10, Duration: 217ms]  
:: Progress: [19778/441118] :: Job [1/1] :: 127 req/sec :: Duration: [0:02:11] :: Errors: 0 :: Go to Settings to activate Windows.
```

/courses

Fuzz the `/courses` directory:

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/directory  
-list-2.3-small.txt:FUZZ -u http://faculty.academy.htb:PORT/courses/FUZZ -e .php,.phps,.php7 -v
```

Discovered page:

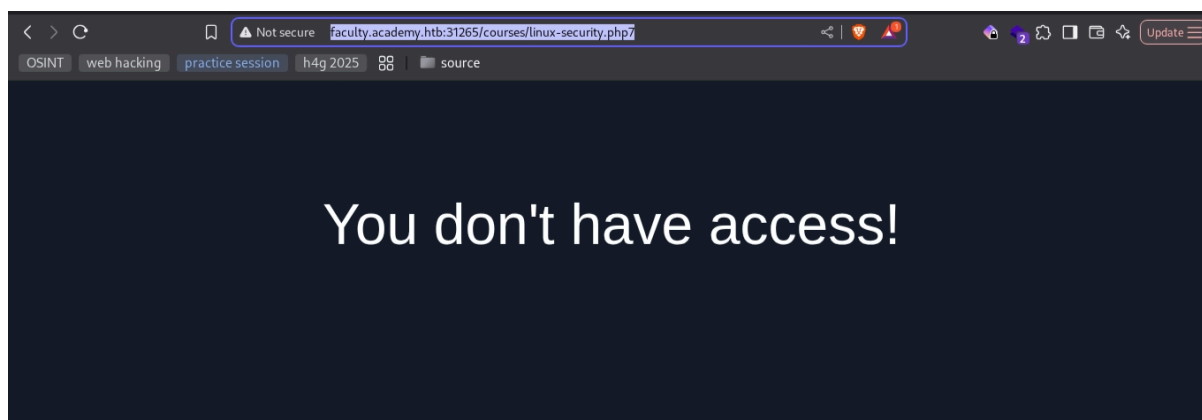
linux-security.php7

Result:

```
[Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4780ms]  
| URL | http://faculty.academy.htb:31591/courses/#  
* FUZZ: #  
[Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 5774ms]  
| URL | http://faculty.academy.htb:31591/courses/# Suite 300, San Francisco, California, 94105, USA.  
* FUZZ: # Suite 300, San Francisco, California, 94105, USA.  
[Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 5778ms]  
| URL | http://faculty.academy.htb:31591/courses/# Attribution-Share Alike 3.0 License. To view a copy of this  
* FUZZ: # Attribution-Share Alike 3.0 License. To view a copy of this  
[Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 5781ms]  
| URL | http://faculty.academy.htb:31591/courses/#  
* FUZZ: #  
[Status: 200, Size: 774, Words: 223, Lines: 53, Duration: 225ms]  
| URL | http://faculty.academy.htb:31591/courses/linux-security.php7  
* FUZZ: linux-security.php7  
:: Progress: [19137/175328] :: Job [1/1] :: 161 req/sec :: Duration: [0:01:55] :: Errors: 0 :: Go to Settings to activate Windows.
```

```
http://faculty.academy.htb:31591/courses/linux-security.php7
```

Accessing the page confirms it displays:



You don't have access!

Question 4

In the page from the previous question, you should be able to find multiple parameters that are accepted by the page. What are they?

flag: user username

Process

First, determine the common response size for invalid parameters:

```
loki@SolarisFortress: ~  
File Actions Edit View Help  
[loki@SolarisFortress] ~  
$ ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt -u http://faculty.academy.htb:31591/courses/linux-security.php7 -X POST -d 'FUZZ=key' -H 'Content-Type: application/x-www-form-urlencoded' -c -ic  
  
v2.1.0-dev  
  
:: Method      : POST  
:: URL         : http://faculty.academy.htb:31591/courses/linux-security.php7  
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt  
:: Header      : Content-Type: application/x-www-form-urlencoded  
:: Data        : FUZZ=key  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout      : 10  
:: Threads     : 40  
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500  
  
Albania [Status: 200, Size: 774, Words: 223, Lines: 53, Duration: 303ms]  
ADAPTER [Status: 200, Size: 774, Words: 223, Lines: 53, Duration: 302ms]  
12 [Status: 200, Size: 774, Words: 223, Lines: 53, Duration: 300ms]  
2 [Status: 200, Size: 774, Words: 223, Lines: 53, Duration: 300ms]  
4 [Status: 200, Size: 774, Words: 223, Lines: 53, Duration: 304ms]  
14 [Status: 200, Size: 774, Words: 223, Lines: 53, Duration: 301ms]
```



```
ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u http://faculty.academy.htb:31591/courses/linux-security.php7 -X POST -d 'FUZZ=key' -H 'Content-Type: application/x-www-form-urlencoded' -c -ic
```

Common response size identified: **774**

Use this value as a filter:

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u http://faculty.academy.htb:31591/courses/linux-security.php7 -X POST -d 'FUZZ=key' -H 'Content-Type: application/x-www-form-urlencoded' -c -ic -fs 774
```

Results:

```
user [Status: 200, Size: 780, Words: 22
3, Lines: 53, Duration: 240ms]
username [Status: 200, Size: 781, Words: 22
3, Lines: 53, Duration: 217ms]
```

Question 5

Try fuzzing the parameters you identified for working values. One of them should return a flag. What is the content of the flag?

flag:

HTB{w3b_fuzz1n6_m4573r}

Process

Using the previously identified parameters, fuzz parameter values to find valid inputs.

Fuzz the `username` parameter using a username wordlist:

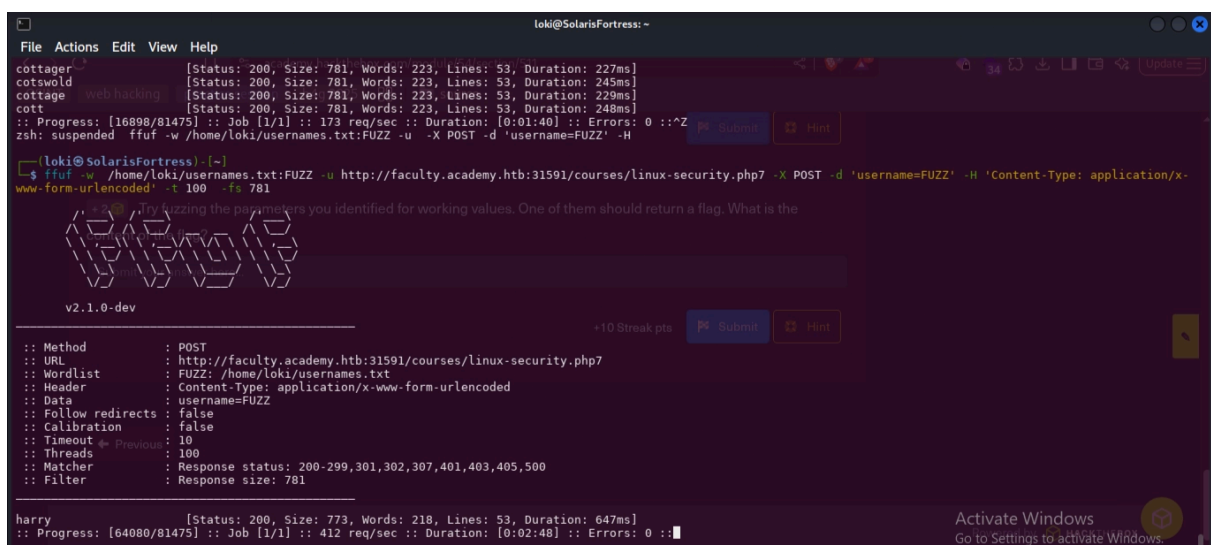
```
ffuf -w /home/loki/usernames.txt:FUZZ -u http://faculty.academy.htb:PORT/courses/linux-security.php7 -X POST -d 'usern
```

```
ame=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -t 100
```

Common invalid response size identified: **781**

Apply filter:

```
ffuf -w /home/loki/usernames.txt:FUZZ -u http://faculty.academy.htb:31591/courses/linux-security.php7 -X POST -d 'username=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -t 100 -fs 781
```



```
loki@SolarisFortress: ~  
File Actions Edit View Help  
cottage- [Status: 200, Size: 781, Words: 223, Lines: 53, Duration: 227ms]  
cotswold [Status: 200, Size: 781, Words: 223, Lines: 53, Duration: 245ms]  
cottage [Status: 200, Size: 781, Words: 223, Lines: 53, Duration: 229ms]  
cott [Status: 200, Size: 781, Words: 223, Lines: 53, Duration: 248ms]  
:: Progress: [16898/81475] :: Job [1/1] :: 173 req/sec :: Duration: [0:01:40] :: Errors: 0 :: ^Z  
zsh: suspended ffuf -w /home/loki/usernames.txt:FUZZ -u http://faculty.academy.htb:31591/courses/linux-security.php7 -X POST -d 'username=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -t 100 -fs 781  
loki@SolarisFortress: ~  
$ ffuf -w /home/loki/usernames.txt:FUZZ -u http://faculty.academy.htb:31591/courses/linux-security.php7 -X POST -d 'username=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -t 100 -fs 781  
v2.1.0-dev  
+10 Streak pts Submit Hint  
:: Method : POST  
:: URL : http://faculty.academy.htb:31591/courses/linux-security.php7  
:: Wordlist : FUZZ: /home/loki/usernames.txt  
:: Header : Content-Type: application/x-www-form-urlencoded  
:: Data : username=FUZZ  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout (s) : 10  
:: Threads : 100  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter : Response size: 781  
harry [Status: 200, Size: 773, Words: 218, Lines: 53, Duration: 647ms]  
:: Progress: [64080/81475] :: Job [1/1] :: 412 req/sec :: Duration: [0:02:48] :: Errors: 0 ::
```

Result:

harry

Retrieve the page content using the valid username:

```
curl http://faculty.academy.htb:PORT/courses/linux-security.php7 -X POST -d 'username=harry' -H 'Content-Type: application/x-www-form-urlencoded'
```

```
loki@SolarisFortress: ~  
File Actions Edit View Help  
academy.hackthebox.com/module/54/section/511  
$ curl http://faculty.academy.htb:31591/courses/linux-security.php7 -X POST -d 'username=harry' -H 'Content-Type: application/x-www-form-urlencoded'  
<div class='center'><p>HTB{w3b_fuzz1n6_m4573r}</p></div>  
<html>  
<!DOCTYPE html>  
<head>  
<title>HTB Academy</title>  
<style>  
*,  
html {  
  margin: 0;  
  padding: 0;  
  border: 0;  
}  
html {  
  width: 100%;  
  height: 100%;  
}  
body {  
  width: 100%;  
  height: 100%;  
  position: relative;  
  background-color: #151D2B;  
}  
.center {  
  width: 100%;  
  height: 50%;  
  margin: 0;  
  position: absolute;  
}
```

The response contains the final flag.